INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Security Policy & Procedural Manual for

International Cybersecurity and Digital Forensics Academy (ICDFA)

Version 1.0

Confidentiality Disclaimer

This document contains sensitive information prepared exclusively for academic and professional purposes under the International Cybersecurity and Digital Forensics Academy (ICDFA) program. Distribution of this document is strictly limited to authorized individuals on a need-to-know basis. The contents shall not be disclosed, copied, printed, or reproduced without prior authorization. Unauthorized use, review, or distribution is strictly prohibited.

Document Control

Name of the Document	Security Policy & Procedural Manual
Policy Version	1.0
Owner of the Policy	Information Security Manager
Executive Sponsor	Executive Director / Deputy CEO
Recommending Committee	Information Security Governance Committee (ISGC)
Next Review Due	1 year from approval date, or earlier in case of regulatory/technological changes

Document Version History

S. No.	Activity	Approval By	Date
1	Security Policy & Procedural Manual v1.0 (Initial Release)	Executive Management / ISGC	August 28, 2025
2	—	—	—
3	—	—	—

Contents

1. Institutional Context – ICDFA 6
1.1. About ICDFA 6
1.2. Mission 6
1.3. Vision 6
1.4. Core Values 7
1.5. Founder's Message 7
2. GRC Policy Analysis – ICDFA Context 7
2.1. Data Types Collected 7
2.2. Applicable Frameworks 7
2.3. Software and Tools Used 8
2.4. Industry Sector 8
3. Executive Summary 8
4. Purpose 8
5. Custody and Access 8
6. Maintenance and Approval 8
7. Objectives 9
8. Scope 9
9. Functions and Ownership 9
10. Enterprise Security Policy 10
10.1. Purpose and Scope 10
10.2. Roles and Responsibilities 10
10.3. Policy Statements 10
10.4. Compliance Requirements 10
10.5. Verification and Metrics 11
10.6. Enforcement and Exceptions 11
10.7. Implementation Strategies 11
10.8. Effectiveness Measurement 12
10.9. Version Control and Review 12
11. Acceptable Use Policy (AUP) 13
11.1. Purpose and Scope 13
11.2. Roles and Responsibilities 13
11.3. Policy Statements 13
11.4. Enforcement 13

11.6. Formal Process for Requesting and Approving Exceptions: 13
11.7. Compliance Requirements 14
11.8. Verification and Metrics 14
11.9. Version Control and Review 14
12. Access Control Policy 15
12.1. Purpose and Scope 15
12.2. Roles and Responsibilities 15
12.3. Policy Statements 15
12.4. Compliance Requirements 16
12.5. Verification and Metrics 16
12.6. Enforcement and Exceptions 16
12.7. Version Control and Review 16
13. Data Classification & Handling Policy 17
13.1. Purpose and Scope 17
13.2. Roles and Responsibilities 17
13.3. Policy Statements 17
13.4. Compliance Requirements 17
13.5. Verification and Metrics 17
13.6. Enforcement and Exceptions 17
13.7. Version Control and Review 18
14. Incident Response Policy 19
14.1. Purpose and Scope 19
14.2. Roles and Responsibilities 19
14.3. Policy Statements (Incident Response Lifecycle) 19
14.4. Incident Response Procedures 19
14.5. Reporting and Communication 20
14.6. Compliance Requirements 20
14.7. Verification and Metrics 20
14.8. Enforcement and Exceptions 20
14.9. Version Control and Review 20
15. Mobile Device Policy 21
15.1. Purpose and Scope 21
15.2. Roles and Responsibilities 21
15.3. Policy Statements 21

15.4. Compliance Requirements 22
15.5. Enforcement and Exceptions 22
15.6. Verification and Metrics 22
15.7. Version Control and Review 22
16. Cloud Security Policy 23
16.1. Purpose and Scope 23
16.2. Roles and Responsibilities 23
16.3. Policy Statements 23
16.4. Compliance Requirements 24
16.5. Verification and Metrics 24
16.6. Enforcement and Exceptions 24
16.7. Version Control and Review 25
17. Physical and Environmental Security Policy 26
17.1. Purpose and Scope 26
17.2. Roles and Responsibilities 26
17.3. Policy Statements 26
17.4. Compliance Requirements 27
17.5. Verification and Metrics 27
17.6. Enforcement and Exceptions 27
17.7. Version Control and Review 27

1. Institutional Context – ICDFA

1.1. About ICDFA

The International Cybersecurity and Digital Forensics Academy (ICDFA) is a not-for-profit institution focused on providing practical, hands-on training in cybersecurity and digital forensics. Its specialized programs are designed to equip individuals with the knowledge and skills necessary to respond effectively to the complex and evolving challenges of the digital security landscape.

ICDFA's training modules cover key areas such as:

- Ethical hacking and penetration testing
- Digital evidence handling and forensic investigations
- Threat analysis and cyber defense techniques
- Incident response and crisis management
- Cyber law, compliance, and regulatory frameworks

Each course is designed and delivered by **industry professionals** to ensure accuracy, relevance, and applicability to current global security threats.

Participants engage in **lab-based exercises, simulated cyberattacks, and forensic case studies** that replicate real-world scenarios. ICDFA also partners with **academic institutions, government agencies, and corporate organizations** to promote digital security awareness and readiness at both local and global levels.

Whether students, IT professionals, or law enforcement officers, participants benefit from ICDFA's **career-focused, practical training** aimed at producing skilled professionals capable of defending and securing digital infrastructures worldwide.

1.2. Mission

To be the globally recognized leader in cybersecurity and digital forensics education, building a skilled, ethical, and future-ready workforce prepared to solve complex digital security challenges. ICDFA empowers individuals with the knowledge, expertise, and practical training necessary to respond effectively to cybersecurity threats across public and private sectors.

1.3. Vision

To cultivate a global community of learners, researchers, and professionals dedicated to creating a safer digital world. ICDFA envisions producing a new generation of cybersecurity leaders who combine technical excellence, innovation, and integrity to protect and defend critical infrastructures worldwide.

1.4. Core Values

- **Excellence –** Delivering high-quality, world-class education and training.
- **Practicality –** Focusing on real-world, hands-on learning experiences.
- **Innovation –** Continuously adapting to evolving cyber threats and technology.
- **Integrity –** Upholding ethical standards in all practices and interactions.
- **Accessibility –** Ensuring inclusivity and access to learners from all backgrounds.
- **Collaboration –** Building partnerships to solve cybersecurity challenges on a global scale.

1.5. Founder's Message

"At ICDFA, our commitment to practical training is complemented by our dedication to robust governance, risk, and compliance (GRC) practices. This Security Policy & Procedural Manual reflects our values of excellence, innovation, and integrity, and ensures that every member of our community plays a role in safeguarding digital trust."

2. GRC Policy Analysis – ICDFA Context

2.1. Data Types Collected

As a training institution, ICDFA primarily collects personally identifiable information (PII) from students, staff, and partners, including:

- Names, contact information, and billing details
- Academic and professional background (for eligibility/certifications)
- Digital forensics training data (e.g., simulated evidence or case studies)

This data includes both administrative records and training-related sensitive data.

2.2. Applicable Frameworks

To operate securely and globally, ICDFA aligns with several frameworks:

- ISO/IEC 27001:2022 – Information Security Management System (ISMS) standard
- NIST Cybersecurity Framework (CSF) – Risk-based approach for cybersecurity governance
- GDPR – General Data Protection Regulation (for EU participants)
- HIPAA – Where training involves handling health-related data
- PCI DSS – If processing online payments for courses
- NDPA/NDPR – Nigeria Data Protection Act/Regulation (for local compliance)

2.3. Software and Tools Used

ICDFA uses specialized tools to deliver and manage training programs:

- Learning Management Systems (LMS) – e.g., Moodle, Blackboard, Canvas
- Cybersecurity Lab Environments – Virtualized or sandboxed training labs
- Digital Forensics Tools – e.g., EnCase, Autopsy, FTK Imager
- Penetration Testing Tools – e.g., Metasploit, Nmap, Wireshark

These platforms support realistic, hands-on training aligned with industry practices.

2.4. Industry Sector

ICDFA operates within the education and professional training sector, specializing in cybersecurity and digital forensics skill development. Unlike traditional academic institutions, ICDFA emphasizes practical, workforce-ready training tailored to meet government, corporate, and law enforcement needs.

3. Executive Summary

The **Security Policy & Procedural Manual** of the **International Cybersecurity and Digital Forensics Academy (ICDFA)** serves as a foundational framework to protect the confidentiality, integrity, and availability of all institutional information assets. It defines clear standards, responsibilities, and processes to ensure security and compliance with international best practices such as ISO 27001:2022, NIST Cybersecurity Framework, HIPAA and other applicable legal and regulatory requirements.

4. Purpose

The purpose of this manual is to provide a comprehensive set of security policies, procedures, and guidelines that safeguard ICDFA's digital and physical assets, promote accountability, and foster a secure academic and operational environment.

5. Custody and Access

This manual is a controlled document maintained by the **Information Security Team**. Access is limited to authorized personnel, while read-only versions are distributed to all employees, contractors, students and stakeholders. Any modification, reproduction or unauthorized distribution is strictly prohibited.

6. Maintenance and Approval

The manual will be reviewed and updated **annually** or upon major changes in regulatory requirements, organizational structure or technology. Updates require approval from **Executive Management** in consultation with the **Information Security Manager**. Version control logs will track all changes to ensure transparency and accountability.

7. Objectives

- Establish a **unified security framework** for ICDFA.
- Ensure **compliance** with global standards and regulations.
- Protect institutional reputation, financial stability, and operational continuity.
- Define **roles and responsibilities** across management, staff, and students.
- Provide structured **incident management and response processes**.
- Promote **awareness and training** among all stakeholders.

8. Scope

The policies and procedures outlined in this manual apply to **all employees, contractors, students, vendors and third parties** with access to ICDFA information systems, networks, data, and physical facilities. This includes both on-premises and cloud-hosted environments, as well as mobile and remote access systems.

9. Functions and Ownership

- **Executive Management** – Provides strategic direction, allocates resources, and approves policies.
- **Information Security Team** – Owns, maintains, and enforces the manual.
- **Employees, Students and Contractors** – Must comply with all security requirements and report incidents.
- **Vendors and Third Parties** – Required to adhere to ICDFA's security policies as part of contractual obligations.

10. Enterprise Security Policy

10.1. Purpose and Scope

The purpose of this Enterprise Security Policy is to define ICDFA's overarching commitment to protecting information assets. It establishes security requirements that apply across all academic, research, and operational activities.

This policy applies to:

- All employees, students, contractors, volunteers, vendors, and third parties.
- Any individual with temporary or permanent access to ICDFA's systems, networks, facilities, or data.
- Both digital and physical information assets.

The Information Security Team shall ensure this policy is communicated to all relevant stakeholders, including new joiners during onboarding.

10.2. Roles and Responsibilities

- **Executive Management:**
  - Accountable for all aspects of ICDFA's information security.
  - Provide oversight, funding, and support for enterprise-wide initiatives.
- **Information Security Team:**
  - Secure IT infrastructure.
  - Identify, analyze, and mitigate security threats and risks.
  - Implement and manage access rights and privileges.
  - Maintain security policy documents and ensure updates.
  - Deliver awareness and training programs.
  - Respond to incidents and support disaster recovery.
  - Ensure infrastructure supports and enforces security policies.
- **Employees, Students, and Contractors:**
  - Comply with all security policies and guidelines.
  - Promptly report any suspected or attempted security breaches.

10.3. Policy Statements

- Information security shall be embedded into all ICDFA academic, research, and operational processes.
- Controls shall be implemented in alignment with ISO/IEC 27001:2022, NIST CSF, and other applicable standards and regulations (GDPR, PCI DSS).
- Information systems and processes must undergo regular risk, compliance, and control effectiveness assessments.
- Executive Management shall allocate sufficient funding, resources, and oversight to ensure a strong security posture.
- All stakeholders (employees, students, contractors, and vendors) must comply with this policy and report incidents immediately to the Information Security Team.

10.4. Compliance Requirements

This policy complies with:

- ISO/IEC 27001:2022 – Information Security Management Systems.
- NIST Cybersecurity Framework (CSF).
- General Data Protection Regulation (GDPR).

10.5. Verification and Metrics

Effectiveness of this policy shall be verified using:

- Annual ISO 27001 internal audits and third-party audits.
- Bi-annual penetration testing and vulnerability assessments.
- Quarterly risk assessment and compliance reviews.
- Key Performance Indicators (KPIs): % of systems patched on time, % of users completing security training.

10.6. Enforcement and Exceptions

- Non-compliance with this policy shall result in disciplinary actions up to and including termination of employment (ICDFA Staff, Vendor, service providers) or training contract(Student).
- Legal actions may be taken where violations involve regulatory breaches.
- Any exceptions to this policy must be formally documented, justified, and approved by the Information Security Manager.

10.7. Implementation Strategies

To ensure effective adoption and compliance with the organization's security policies, the following strategies will be implemented:

- **Communication Campaign**
  Security policies will be formally communicated through official emails, intranet postings, and periodic staff briefings to ensure all employees are aware of their responsibilities.
- **Training & Awareness**
  Regular training sessions, phishing simulations, and annual refresher programs will be conducted to enhance awareness and competency in security practices.
- **Leadership Support**
  Executive leadership will endorse and promote security initiatives to demonstrate organizational commitment and foster a culture of accountability.
- **Phased Implementation**
  Policies will be introduced in phases, prioritizing critical areas first, to ensure smooth adoption and minimize operational disruption.
- **Supporting Tools**
  Security technologies such as Mobile Device Management (MDM), Data Loss Prevention (DLP), Security Information and Event Management (SIEM), and access control systems will be implemented to enforce compliance.
- **Monitoring & Feedback**
  Regular audits, compliance checks, and feedback surveys will be conducted to evaluate the effectiveness of security measures and identify areas for improvement.
- **Recognition & Incentives**
  Employees who consistently demonstrate compliance and support security practices will be acknowledged through recognition programs and performance incentives.
- **Continuous Improvement**
  Security policies and practices will be reviewed annually, and after major

incidents, to ensure alignment with evolving threats, technologies, and regulatory requirements.

10.8. Effectiveness Measurement

The effectiveness of the security policies will be measured using the following criteria:

- **Compliance Metrics**
  Monitoring through periodic audits, self-assessments, and compliance reports to verify adherence to policies.
- **Incident Metrics**
  Tracking the number, severity, and resolution times of security incidents to assess operational resilience.
- **Awareness Metrics**
  Measuring training completion rates, employee quiz results, and phishing simulation outcomes to evaluate awareness levels.
- **Exception Tracking**
  Documenting and analyzing granted policy exceptions to identify potential risks and patterns of non-compliance.
- **Risk Reduction Metrics**
  Comparing results of risk assessments conducted before and after policy implementation to evaluate overall risk reduction.

10.9. Version Control and Review

- **Version:** 1.0
- **Approval Date:** 28.08.2025
- **Next Review Date:** 28.08.2026
- **Review Frequency:** Annually or upon major regulatory/operational change.

11. Acceptable Use Policy (AUP)

11.1. Purpose and Scope

The purpose of this Acceptable Use Policy (AUP) is to guide appropriate user behavior when accessing ICDFA networks, websites, platforms, or IT resources. It establishes acceptable and unacceptable practices to safeguard ICDFA systems against misuse, mitigate risks, and preserve the confidentiality, integrity, and availability of institutional data.

This policy applies to:

- All employees, contractors, interns, consultants, and third parties with access to ICDFA resources.
- All devices including computers, mobile devices, cloud services, messaging platforms, and storage systems.
- All environments including on-premises, remote work, and any location where ICDFA resources are accessed.

11.2. Roles and Responsibilities

- **Users:** Operate systems within authorized limits, protect login credentials, and comply with AUP.
- **Employees:** Ensure compliance with this policy, report violations promptly, and monitor access control.
- **Third Parties:** Conduct activities in compliance with ICDFA's AUP.
- **Management:** Provide awareness training, monitor compliance, approve exceptions, and enforce disciplinary action where necessary.

11.3. Policy Statements

- Protect user login credentials; sharing passwords is prohibited.
- Access ICDFA systems only through secure, authorized channels.
- Devices must be used for work-related or educational purposes only.
- Devices must be updated regularly with security patches and antivirus software.
- ICDFA systems must not be used for personal gain, harassment, or disruption of services.
- Unauthorized access attempts or monitoring of data are strictly prohibited.
- Policy violations must be reported immediately to supervisors or managers.

11.4. Enforcement

- Users who violate this policy may face disciplinary action, including suspension, termination, or legal penalties.
- Access privileges may be blocked or revoked for violators.
- All members of ICDFA are authorized to use resources only in line with this policy.

11.5. Exceptions

Exceptions may be granted under specific circumstances, subject to documented approval.

- Exceptions must be requested in advance with full justification, scope, and duration.
- Emergency exceptions may be approved verbally but must be logged and justified afterwards.
- Approved exceptions must be documented, time-limited, and subject to periodic review.

11.6. Formal Process for Requesting and Approving Exceptions:

1. User identifies a need conflicting with the AUP.

2. User completes the formal exception request form (justification, scope, duration, risks).
3. Request submitted for validation and risk assessment by IT Security/Compliance.
    - **Low risk:** Approved by IT Security Manager.
    - **High risk:** Requires joint approval (IT Security Manager, Compliance Officer, Data Protection Officer, CIO/CISO).
4. Record maintained with requestor details, approval date, duration, risk summary, and approvers.

11.7. Compliance Requirements

This policy complies with:

- GDPR – Personal Data Protection.
- HIPAA – Healthcare Data Security.
- ISO/IEC 27001 – Information Security Management.
- PCI DSS – Payment Card Security.

11.8. Verification and Metrics

Effectiveness will be measured by:

- **Technical Monitoring:** Logging, intrusion detection, antivirus and patch compliance, device posture monitoring.
- **Policy Acknowledgement:** Annual digital/physical confirmation of AUP awareness.
- **Access Control Audits:** Regular reviews of privileges, accounts, and roles.
- **Training & Testing:** Security awareness sessions, quizzes, and simulations to validate understanding.

11.9. Version Control and Review

- **Version:** 1.0
- **Approval Date:** 28.08.2025
- **Next Review Date:** 28.08.2026
- **Review Frequency:** Annually or upon major regulatory/operational change.

12. Access Control Policy

12.1. Purpose and Scope

The purpose of this policy is to establish secure and standardized measures for managing access to ICDFA's platforms, systems, applications, and physical facilities. Access will be granted strictly on a need-to-know and least privilege basis, depending on the individual's role and responsibilities.

This policy applies to:

- Students and program participants
- Employees and administrators
- Contractors, vendors, and authorized third parties
- Guest lecturers and visiting professionals

Covered environments include:

- Digital learning platforms and cyber forensic labs
- Administrative systems, networks, and cloud environments
- Physical training facilities and secure server areas

12.2. Roles and Responsibilities

- Students and Program Participants: Access only assigned labs and training systems, follow guidelines, and report suspicious activity.
- Instructors and Trainers: Manage access for students, ensure ethical use of labs, and report violations.
- Employees (Admin, IT, InfoSec): Implement RBAC, MFA, VPN; provision/de-provision accounts; monitor logs, investigate incidents, and perform periodic reviews.
- Guests: Comply fully with ICDFA's access policies.

12.3. Policy Statements

- Role-Based Access Control (RBAC): Permissions shall be assigned based on predefined roles aligned with institutional responsibilities.
- Least Privilege Principle: Users shall be granted only the minimum access required for their duties.
- Multi-Factor Authentication (MFA): Mandatory for all critical systems and sensitive data repositories.
- Inactive Account Management: Accounts inactive for 7+ days will be suspended; accounts inactive for 90+ days will be disabled and reviewed before reactivation.
- Remote Access: Permitted only via secure, encrypted VPN connections approved by ICT.
- Access Provisioning and De-Provisioning: Requests must be approved via access forms; access is revoked immediately upon termination, withdrawal, or role change.
- User Access Reviews: Conducted quarterly to verify role alignment and least privilege.
- Segregation of Duties: No individual may complete end-to-end processes without oversight (e.g., maker-checker separation).
- Physical Access: Entry to labs, server rooms, and secure areas requires access cards or biometrics; all entries must be logged.

12.4. Compliance Requirements

This policy supports compliance with:

- ISO/IEC 27001:2022
- GDPR – Data Protection by Design and Default
- NIST SP 800-53 – Access Control Controls.

12.5. Verification and Metrics

Activity	Frequency	Owner
User access rights review	Quarterly	IT / InfoSec / Management
Dormant account audit & deactivation	Monthly	IT
Log analysis for unauthorized access attempts	Ongoing	Security Operations
Violation investigation	Ongoing	Security Operations

12.6. Enforcement and Exceptions

- Violations may result in suspension of access, disciplinary action, termination, or legal consequences for breaches of confidentiality or misuse of sensitive data.
- Exceptions will only be granted with documented justification, and approval from the Information Security Manager, and must be time-bound, monitored, and subject to audit.

12.7. Version Control and Review

- **Version:** 1.0
- **Approval Date:** 28.08.2025
- **Next Review Date:** 28.08.2026
- **Review Frequency:** Annually or upon major regulatory/operational change.

13. Data Classification & Handling Policy

13.1. Purpose and Scope

The purpose of this policy is to ensure that all data handled by the International Cybersecurity and Digital Forensics Academy (ICDFA) is protected according to its sensitivity and value. This policy applies to all staff, students, contractors, and third-party service providers interacting with ICDFA's digital or physical data assets.

13.2. Roles and Responsibilities

- Data Owners (Department Heads): Responsible for classifying the data they generate or manage.
- IT Security Team: Ensures technical controls align with classification requirements.
- All Users: Must handle data strictly according to its assigned classification.

13.3. Policy Statements

ICDFA classifies data into four categories, each with specific handling requirements:

- Public – Data that may be shared openly without risk (e.g., published research abstracts, marketing materials).
- Handling: Must be reviewed for accuracy before release.
- Internal Use Only – Data restricted to internal organizational use (e.g., meeting notes, internal memos).
- Handling: Shared only within authorized teams.
- Confidential – Sensitive data that could cause harm if disclosed (e.g., student grades, staff evaluations).
- Handling: Stored in secure systems with access logging.
- Restricted – Highly sensitive data requiring strict access control (e.g., forensic case files, system credentials).
- Handling: Must be encrypted at rest and in transit.

13.4. Compliance Requirements

This policy supports compliance with:

- GDPR – General Data Protection Regulation.
- ISO/IEC 27001 – Information Security Management.
- NDPR – Nigeria Data Protection Regulation.

13.5. Verification and Metrics

- Regular audits to ensure correct data classification.
- Tracking incidents involving misclassified or mishandled data.
- Compliance monitoring for encryption and access controls.
- KPIs:
  - 100% of accounts reviewed within SLA.
  - ≤1% dormant accounts left unpremeditated per cycle.
  - Zero unauthorized administrative privilege grants per quarter.

13.6. Enforcement and Exceptions

- Non-compliance may result in retraining, disciplinary action, or termination depending on severity.

- Exceptions must be requested formally, justified, and approved of by the Chief Compliance Officer.

13.7. Version Control and Review

- **Version:** 1.0
- **Approval Date:** 28.08.2025
- **Next Review Date:** 28.08.2026
- **Review Frequency:** Annually or upon major regulatory/operational change.

14. Incident Response Policy

14.1. Purpose and Scope

The purpose of this Incident Response Policy is to establish a structured and proactive framework for detecting, reporting, analyzing, responding to, and recovering from cybersecurity incidents at ICDFA. It ensures timely mitigation of threats, protection of critical assets, compliance with laws and standards, and continuous improvement of ICDFA's cybersecurity posture.

This policy applies to:

- All staff, faculty, contractors, interns, students, and third-party service providers engaged with ICDFA.
- All information systems, networks, cloud resources, research databases, forensic labs, and communication platforms owned or managed by ICDFA.
- Any cybersecurity event that may impact confidentiality, integrity, or availability of ICDFA's data, assets, intellectual property, or forensic evidence.

14.2. Roles and Responsibilities

- **Director of IT:** Classifies incidents, triggers CSIRT meetings, ensures incident handling lifecycle is followed.
- **Chief Information Security Officer (CISO):** Oversees the entire incident lifecycle, manages forensic evidence, liaises with law enforcement, ensures compliance.
- **Incident Response Coordinators (IRC):** Collect incident data, facilitate analysis, containment, and documentation.
- **Incident Response Handlers (IRH):** Investigate, preserve, and analyze evidence; support containment, eradication, and recovery.
- **Insider Threat Watch:** Detect and manage risks posed by insiders with privileged access.
- **Law Enforcement & Legal Counsel:** Coordinate with ICDFA leadership to ensure lawful evidence handling, external communication, and disclosures.
- **Users:** Report incidents promptly and follow defined reporting procedures.

14.3. Policy Statements (Incident Response Lifecycle)

ICDFA follows six defined phases for effective incident handling:

1. **Assessment** – Evaluate potential events to confirm incidents, gauge severity, and document actions.
2. **Detection** – Identify incidents through tools, alerts, or user reports; classify and escalate as required.
3. **Containment** – Limit damage, safeguard systems, block malicious activity, and minimize business disruption.
4. **Investigation & Analysis** – Determine root cause, scope, attacker intent, and affected assets.
5. **Recovery** – Restore systems securely, patch vulnerabilities, verify system integrity, and resume operations.
6. **Post-Incident Review** – Conduct lessons learned, update response plans, and improve resilience.

14.4. Incident Response Procedures

- **Discovery:** Staff report incidents immediately with details (system, severity, identifiers).

- **CSIRT Activation:** Director of IT notifies the Cyber Security Incident Response Team.
- **Classification:** Incidents are categorized as Reportable, Minor, Major, or Critical (triggers BCP if required).
- **Containment & Remediation:** Includes isolating systems, changing credentials, and forensic investigation.
- **Notification:** Internal stakeholders, leadership, regulators, and law enforcement are notified as required.
- **Restoration:** Systems rebuilt or restored from backups; ensure patches, antivirus, and monitoring are active.
- **Documentation:** All steps recorded in an Incident Assessment Checklist.
- **Review:** CSIRT evaluates effectiveness, identifies gaps, and updates procedures.

14.5. Reporting and Communication

- **Internal:** All incidents reported to Director of IT and CSIRT. Critical incidents escalated to CISO, Executive Director, and Academic Leads.
- **External:** Regulators (e.g., NDPA authority) notified within statutory timelines. Law enforcement engaged through Legal Counsel.
- **Principle:** All external communications follow the "One Voice" rule, coordinated by Communications/PR Lead. Unauthorized disclosure is prohibited.

14.6. Compliance Requirements

This policy complies with:

- ISO/IEC 27035 – Information Security Incident Management.
- NIST SP 800-61 – Computer Security Incident Handling Guide.
- Nigerian Data Protection Act (NDPA).
- Other applicable laws, contracts, and sector standards.

14.7. Verification and Metrics

- **Audits:** Internal reviews of incident logs and IMS records.
- **Incident Metrics:** MTTD, MTTR, % resolved within SLA, post-incident review completion.
- **Awareness Assessments:** Training participation, surveys, and simulation exercises.

14.8. Enforcement and Exceptions

- **Enforcement:** Non-compliance may result in disciplinary actions (termination, expulsion, contract cancellation) or legal consequences.
- **Exceptions:** Must be requested in writing, reviewed by CISO, and approved by the Executive Director. All exceptions are logged and auditable.

14.9. Version Control and Review

- **Version:** 1.0
- **Approval Date:** 28.08.2025
- **Next Review Date:** 28.08.2026
- **Review Frequency:** Annually or upon major regulatory/operational change.

15. Mobile Device Policy

15.1. Purpose and Scope

The purpose of this Mobile Device Policy is to define security requirements for all mobile devices, including smartphones, tablets, laptops, and portable storage devices that access ICDFA's systems or data. The policy applies to both corporate-owned and personally-owned (BYOD) devices.

This policy applies to all staff, students, contractors, and third parties using mobile devices for organizational purposes, covering:

- Corporate and BYOD devices.
- Devices accessing organizational networks, applications, or data.
- On-premises, remote, and mobile environments.

15.2. Roles and Responsibilities

- **ICDFA Management** – Approves this policy, allocates resources, and oversees compliance.
- **IT Department** – Enforces Mobile Device Management (MDM) controls, configures security settings, monitors compliance, and responds to mobile security incidents.
- **Staff and Students** – Register devices with IT, comply with security requirements, and report lost or compromised devices immediately.
- **Third Parties** – Adhere to this policy and ensure their devices meet security standards before accessing ICDFA resources.

15.3. Policy Statements

- All mobile devices accessing ICDFA resources must be pre-approved and registered with IT.
- Multi-Factor Authentication (MFA) and automatic screen locks (2–5 minutes) are mandatory.
- Operating systems and security patches must be up to date.
- All organizational data stored on mobile devices must be encrypted; full-disk encryption is mandatory.
- Remote access is permitted only via secure VPN connections approved by IT.
- BYOD devices must be enrolled in MDM; business data must be isolated from personal data.
- Unauthorized activities (jailbreaking, rooting, disabling security controls) are strictly prohibited.
- Use of personal cloud storage or removable media for organizational data is not permitted without IT approval.

- Lost, stolen, or compromised devices must be reported immediately. ICDFA reserves the right to remotely wipe institutional data.
- Monitoring and auditing of mobile device access will be performed regularly.

15.4. Compliance Requirements

This policy supports compliance with:

- ISO/IEC 27001:2022 – Information Security Management Systems.
- GDPR – Data Security and Privacy for BYOD.
- NIST SP 800-124 – Guidelines for Managing the Security of Mobile Devices.
- Nigeria Data Protection Act (2023).

15.5. Enforcement and Exceptions

- **Enforcement:** Non-compliance may result in:
  - Termination of employment, contracts, or enrollment.
  - Suspension/termination of network or BYOD access.
  - Legal action in cases of severe breaches.
- **Exceptions:** Granted only with documented justification and approval by the CISO. All exceptions must be time-limited, logged, and reviewed periodically.

15.6. Verification and Metrics

The effectiveness of this policy will be measured by:

- **Quarterly compliance audits** of devices and access logs.
  - *Metric:* % of devices enrolled in MDM vs. non-compliant.
- **Incident tracking** of lost/stolen devices and resolution times.
  - *Metric:* Average resolution time (e.g., wiping data).
- **Patching and encryption compliance monitoring.**
  - *Metric:* Breach rates post-patching/encryption.
- **Stakeholder feedback.**
  - *Metric:* Number of implemented recommendations for improvement.

15.7. Version Control and Review

- **Version:** 1.0
- **Approval Date:** 28.08.2025
- **Next Review Date:** 28.08.2026
- **Review Frequency:** Annually or upon major regulatory/operational change.

16. Cloud Security Policy

16.1. Purpose and Scope

The purpose of this Cloud Security Policy is to establish a rigorous framework of guidelines and security mandates for the use of cloud computing services within ICDFA. Its objectives are to:

- Safeguard institutional data, systems, and cloud infrastructures against unauthorized access, disclosure, or destruction.
- Maintain the confidentiality, integrity, and availability of ICDFA's cloud-hosted assets.
- Ensure compliance with regulatory, contractual, and industry standards.
- Reinforce ICDFA's commitment to pioneering cybersecurity and digital forensics education.

This policy applies to all:

- Cloud service models (IaaS, PaaS, SaaS).
- Deployment models (public, private, hybrid, multi-cloud).
- Institutional data, applications, and infrastructure hosted in the cloud.
- Users, including employees, contractors, interns, students, faculty, staff, and third-party vendors who access or manage ICDFA's cloud resources

16.2. Roles and Responsibilities

- Chief Information Security Officer (CISO): Approves cloud providers, manages organizational cloud risks, reports to leadership, and owns this policy.
- Cloud Governance Committee: Interdisciplinary body evaluating cloud deployments, approving exceptions, and reviewing updates.
- IT Security Team: Implements technical controls, configures security settings, monitors threats, and leads incident response.
- Department Heads / Program Directors: Approve cloud service use in their areas, ensure staff compliance, and promote awareness.
- Individual Users: Protect credentials, comply with policy requirements, complete cloud training, and report incidents.

16.3. Policy Statements

- Cloud Service Procurement: All cloud services require prior approval by the IT Security Team, referencing frameworks (ISO 27001, SOC 2, CSA STAR).
- Data Classification & Encryption: All data must be classified per the ICDFA Data Classification Policy. Sensitive data must be encrypted in transit (TLS 1.2+) and at rest (AES-256). Prohibited data categories must not be stored in the cloud.
- Identity & Access Management: Access follows least privilege and need-to-know. MFA is mandatory for privileged accounts. Quarterly access reviews and identity federation are required.

- Configuration & Hardening: All cloud services must follow CIS benchmarks. CSPM (Cloud Security Posture Management) tools are required for monitoring misconfigurations.
- Monitoring & Logging: All logs must be centralized into ICDFA's SIEM. Critical logs retained for 1 year; standard logs for 90 days. Alerts must be automated.
- Third-Party Risk Management: Vendors must undergo annual assessments and submit SOC 2/ISO 27001 certifications.
- Business Continuity & DR: Backups of critical data must be encrypted, geo-redundant, and regularly tested.
- Secure Development: All custom cloud apps must follow secure SDLC practices, including security testing of APIs.
- Mobile & Remote Access: Mobile/cloud access must comply with ICDFA's Mobile Device Policy and secure VPN/SASE.
- Training & Awareness: Annual cloud security training is mandatory for all cloud users.

16.4. Compliance Requirements

This policy complies with:

- ISO/IEC 27001:2022 – ISMS Standard.
- ISO/IEC 27017 – Cloud Security.
- ISO/IEC 27018 – PII in the Cloud.
- NIST Cybersecurity Framework (CSF).
- NIST SP 800-53 / SP 800-144 – Cloud security guidance.
- CSA Cloud Controls Matrix (CCM).
- GDPR / NDPR – Data protection laws.
- PCI DSS – For payment systems.

16.5. Verification and Metrics

- Compliance Metrics: % of cloud resources configured per baselines (>95% target).
- Training Metrics: 100% completion rate for cloud training.
- Incident Metrics: MTTD < 4 hours; MTTR < defined SLA.
- Audit Metrics: % of critical findings remediated within SLA (target = 100%).
- Awareness Metrics: Annual knowledge checks, role-based technical assessments, tabletop exercises.

16.6. Enforcement and Exceptions

- Enforcement: Non-compliance may result in disciplinary action (termination of employment, student expulsion, contract cancellation), suspension of access, or legal action.

- Exceptions: Must be requested in writing to the CISO with justification, risk assessment, and mitigation. Exceptions longer than 30 days require Cloud Governance Committee approval.

16.7. Version Control and Review

- **Version:** 1.0
- **Approval Date:** 28.08.2025
- **Next Review Date:** 28.08.2026
- **Review Frequency:** Annually or upon major regulatory/operational change.

17. Physical and Environmental Security Policy

17.1. Purpose and Scope

The purpose of this Physical Security Policy (PSP) is to safeguard ICDFA's physical assets, facilities, and personnel from unauthorized access, theft, damage, sabotage, or other physical threats. By protecting physical environments, ICDFA reduces the risk of both human and digital exposures that could lead to operational disruption or compromise.

This policy applies to all:

- ICDFA staff, contractors, vendors, and visitors.
- Physical assets (facilities, classrooms, data centers, forensic labs, equipment).
- Personnel and students accessing ICDFA-controlled environments

.

17.2. Roles and Responsibilities

- Management (Board, CEO, HR): Allocate resources, enforce compliance, and ensure adherence to standards.
- Facilities Team (CSO, Guards, Facility Managers): Manage access control, CCTV, and environmental protections; maintain security systems.
- IT Team: Protect IT infrastructure against physical threats, manage access restrictions, report incidents.
- Employees & Contractors: Follow procedures, use facilities responsibly, and report breaches immediately.
- Students & Visitors: Comply with security protocols, require escorts in restricted areas, and avoid tampering with security equipment.
- Chief Information Security Officer (CISO): Oversee implementation and compliance with the Physical Security Policy.

17.3. Policy Statements

- All ICDFA facilities shall implement access control systems, ID badges, and visitor management protocols.
- Secure areas such as server rooms and data centers shall only be accessible to authorized personnel with biometric or electronic access
- CCTV surveillance and alarm systems shall be deployed across critical areas and monitored 24/7.
- Environmental controls such as fire suppression, backup power systems, and water leak detection shall be implemented in sensitive areas.
- Emergency response drills (fire, flood, intrusion) shall be conducted periodically to ensure staff readiness.

17.4. Compliance Requirements

This policy complies with:

- **ISO/IEC 27001:2022** – Physical and Environmental Security.
- **NIST SP 800-53** – PE (Physical & Environmental Controls).
- **GDPR** – For facilities storing EU citizen data.
- Local workplace safety and surveillance regulations.
- Annual physical security audits by internal or external assessors.

17.5. Verification and Metrics

- Quarterly inspection of physical facilities and secure areas.
- Monthly review of visitor logs and access records.
- Annual fire safety and environmental risk drills.
- KPI: % uptime of surveillance, alarm, and environmental control systems.

17.6. Enforcement and Exceptions

- Enforcement: Violations may result in disciplinary action (termination, suspension, legal action, access revocation).
- Exceptions: Must be requested in writing, reviewed by the CISO, and approved by the Security Governance Committee. Exceptions require justification, defined duration, and mitigation measures.

17.7. Version Control and Review

- **Version:** 1.0
- **Approval Date:** 28.08.2025
- **Next Review Date:** 28.08.2026
- **Review Frequency:** Annually or upon major regulatory/operational change.

Contributors and Group 5 Member List:

- Eniola Ibiyemi Fatimah
- Amadi Oluchi Faith
- Naomi Oluchi Edozie
- Titilayo Kwevi
- Valentine Momanyi
- Lyne Achieno Munyolo
- Sarah Onyioze Jatto
- Ene Rita Otalu
- Adanna Somtochukwu Onu
- Dolapo Odeyemi
- Najma Abdi Omar
- Lilly Adjei
- Bilkisu Hussaini
- Javeria Hassan
- Esther Kubeh Awuku
- Emediong Bassey
- Adejuwon Ruqoyat Adebisi
- Ojimba Anita
- Priscilla Azilafu
- Deborah Orimikoya
- Joy Wekesa
- Winner Osahenrhun Ayevbuomwan
- Okafor Chinazaekpere Miracle
- Oreofe Omowunmi Dada
- Rosemary Edet
- Olasubomi Olakunle
- Abimbola Olowoporoku
- Adeoye Adedoyin
- Toyyibah Abiola Adewale